



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-10520 Ivanti Sentry OS Command Injection Vulnerability

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-12
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-10520 Ivanti Sentry OS Command Injection Vulnerability - Vulnerability Report

Published: 2026-06-12 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

1. Executive Summary

CVE-2026-10520 is a critical pre-authentication OS command injection vulnerability affecting Ivanti Sentry, formerly MobileIron Sentry. Ivanti, CISA KEV, and NVD align on the core impact: versions earlier than `R10.5.2`, `R10.6.2`, and `R10.7.1` can allow a remote unauthenticated attacker to execute commands as `root` on the appliance. Because Sentry commonly sits at the boundary between internet-reachable mobile traffic and internal enterprise services such as Exchange, mail gateways, and application back ends, successful exploitation can shift rapidly from appliance compromise to credential theft, session hijacking, and downstream access into business workflows the gateway was meant to protect.

The most important exposure qualifier in the reviewed public record is not simply “Sentry installed,” but “Sentry reachable.” CISA's KEV description and secondary reporting emphasize that exploitation is most practical where the appliance is in an unmanaged state with externally reachable endpoints. By contrast, environments that front Sentry with EPMM mutual TLS enforcement or tightly restricted HTTPS access through Neurons for MDM reduce opportunistic internet exposure, though they should not treat those controls as a substitute for patching because internal reachability, misconfiguration, or partial exposure can still leave exploitable pathways.

The exploitation timeline is unusually compressed. CISA added the CVE to KEV on 2026-06-11, watchTower published technical analysis and a detection artifact generator shortly after disclosure, and Shadowserver-referenced secondary reporting stated that public PoC-driven exploitation attempts were already being observed, with at least a subset of exposed instances reportedly backdoored. Even where those post-disclosure compromise claims are treated with medium confidence because they rely on secondary reporting around Shadowserver observations, the combined signal is clear: organizations should assume that any internet-exposed unpatched Sentry appliance is at high risk of rapid opportunistic exploitation.

Immediate priorities are to upgrade to `R10.5.2`, `R10.6.2`, or `R10.7.1` (or later), identify every externally reachable `/mics` interface, restrict direct internet access wherever business operations permit, review whether the appliance may already be compromised, and hunt for suspicious requests to the publicly discussed configuration endpoint plus signs of post-exploitation command execution on or through the gateway.

Executive takeaway	Assessment
Business impact	Root-level compromise of an internet-facing mobile security gateway can expose credentials, session tokens, mail access, and trusted routing paths into internal services.
Most exposed environments	Unpatched Ivanti Sentry appliances with externally reachable `/mics` endpoints, especially unmanaged or broadly internet-exposed deployments.
Public exploitation status	KEV-listed and supported by medium-confidence post-disclosure reporting of active exploitation attempts shortly after public PoC release.
Immediate priority	Patch now, restrict exposure, validate compromise status, and review logs for requests to `/mics/api/v2/sentry/mics-config/handleMessage`.

2. Intelligence Requirement

This review addresses the following intelligence requirement: what does the current public record say about `CVE-2026-10520`, which Ivanti Sentry deployments are materially exposed, what defensive conclusions can be drawn from the rapidly evolving exploitation picture, and what should security, infrastructure, and detection teams do immediately?

Question	Assessment
What is the vulnerability?	An unauthenticated OS command injection flaw in Ivanti Sentry that can permit root-level remote code execution.

Which versions are affected?	Versions earlier than `R10.5.2`, `R10.6.2`, and `R10.7.1`; secondary reporting phrases this as `10.5.1`, `10.6.1`, `10.7.0`, and prior.
Why is exposure especially serious?	Sentry is a security gateway positioned between mobile devices and internal enterprise services, so appliance compromise can become identity, mail, or application-access compromise.
Are all Sentry deployments equally exposed?	No. The reviewed public record indicates unmanaged and externally reachable interfaces are at highest risk; mTLS with EPMM or tightly restricted HTTPS access can reduce opportunistic exposure but does not replace patching.
Is exploitation theoretical only?	No. CISA added the issue to KEV, public PoC material exists, and secondary reporting cites Shadowserver observations of rapid exploitation attempts after disclosure.
What matters most to defenders?	Fast patching, exposure reduction, compromise assessment, and log hunting tied to the discussed `/mics` API path and unusual appliance-side command execution.

3. Source Review and Confidence

Source	Contribution	Confidence
Ivanti security advisory	Canonical vendor remediation, affected-version range, and primary product guidance for `CVE-2026-10520` and the paired `CVE-2026-10523`.	High
CISA KEV catalog / KEV JSON feed	Confirms known-exploited status, due date, exposure qualifier language, and recommended federal response urgency.	High
NVD JSON 2.0 record	Corroborates CVE description, `CVSS 10.0`, `CWE-78`, and reference set.	High
watchTowr technical analysis	Provides the most useful public technical context on reachable `/mics` application paths, the vulnerable configuration handler, and patch-diff findings.	High
watchTowr GitHub detection artifact generator	Confirms a publicly discussed request path (`/mics/api/v2/sentry/mics-config/handleMessage`) that defenders can use as a hunt pivot.	High
Help Net Security reporting	Adds accessible operational context on affected versions, likely blast radius, and follow-on reporting referencing Shadowserver observations.	Medium
The Hacker News / other secondary coverage	Corroborates patch release timing and severity but does not materially exceed the vendor and research sources.	Medium

Confidence is high on the existence of the vulnerability, affected versions, severity, and immediate need to patch because those facts are directly supported by Ivanti, CISA, and NVD. Confidence is also high that the publicly discussed exploit

surface includes the `/mics` application and a configuration-handling endpoint because the watchTower technical analysis and companion detection artifact generator are specific and internally consistent.

Confidence is only medium on the precise scale of live exploitation at the time of writing because the strongest compromise claims available in the reviewed source set are relayed through secondary reporting that cites Shadowserver observations, rather than a primary Shadowserver technical bulletin accessible in the source set. Even with that caveat, defenders should not anchor on uncertainty: KEV inclusion, public technical detail, and early exploitation reporting together justify emergency handling.

4.1 Core Vulnerability Metadata

Field	Value
CVE	`CVE-2026-10520`
Vulnerability name	`Ivanti Sentry OS Command Injection Vulnerability`
Weakness	`CWE-78` Improper Neutralization of Special Elements used in an OS Command
Severity	`10.0 / CRITICAL` (CVSS v3.1)
CVSS vector	`AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H`
Product	Ivanti Sentry (formerly MobileIron Sentry)
Affected versions	Versions earlier than `R10.5.2`, `R10.6.2`, and `R10.7.1`
Fixed versions	`R10.5.2`, `R10.6.2`, `R10.7.1`
Privileges required	None
User interaction	None
Public disclosure date	`2026-06-09` in the NVD record
KEV add date	`2026-06-11`
CISA action due date	`2026-06-14`
Publicly discussed exploit surface	`/mics/api/v2/sentry/mics-config/handleMessage`
Public exploitation posture	Known exploited per KEV; public PoC and medium-confidence reports of rapid exploitation attempts

4.2 Exposure Interpretation

Exposure pattern	Why it matters	Confidence
Internet-reachable Sentry appliance exposing `/mics`	The public technical material indicates the vulnerable command path is reachable over the web application surface.	High
“Unmanaged state” deployment with externally reachable endpoints	CISA’s KEV language explicitly frames this as the highest-risk condition.	High

Deployments brokering access to Exchange, email, or internal mobile application traffic	Gateway compromise can expose credentials, session material, and trusted internal service paths.	High
Environments relying on mTLS with EPMM or tightly restricted HTTPS through Neurons for MDM	These controls may reduce direct opportunistic reachability, but misconfiguration or partial exposure can still leave exploitable paths.	Medium
Appliance deployments already targeted after public PoC release	Secondary reporting tied to Shadowserver suggests that once a vulnerable host is reachable, time-to-exploitation may be measured in hours rather than days.	Medium

4.3 Realistic Attack Scenarios

Scenario	Description	Defensive implication
Direct internet exploitation of an exposed gateway	An unauthenticated attacker reaches the vulnerable <code>/mics`</code> handler and executes system commands as <code>root`</code> .	Patch and external access reduction are both urgent; perimeter exposure alone can be enough.
Follow-on credential and session theft after appliance compromise	Because Sentry brokers trusted traffic, an attacker can pivot from root on the gateway to stolen sessions, mail access, or impersonation of legitimate users.	Response should include credential review, token/session invalidation, and downstream service validation, not just appliance patching.
Post-PoC opportunistic mass scanning	Attackers replay public exploit logic against internet-exposed Sentry hosts shortly after technical details emerge.	Defenders should assume noisy internet scanning plus selective backdooring and review logs beginning at disclosure time, not merely after internal alerting.

4.4 Analyst Findings

Finding	Defensive implication
This is a perimeter-to-root gateway compromise issue, not a low-impact admin-panel defect.	Treat it as emergency infrastructure exposure with downstream business-system consequences.
The reviewed public record includes an actionable request path for hunting.	Log review can begin immediately around <code>/mics/api/v2/sentry/mics-config/handleMessage`</code> and adjacent <code>/mics`</code> traffic.
Exposure is strongly shaped by reachability, but reduced reachability is not remediation.	Network restrictions help triage and containment, yet full risk reduction still requires patching and compromise assessment.
The public exploitation timeline appears compressed.	Delay materially increases the chance that exposed systems have already been probed or compromised.

5. Threat Context

Ivanti Sentry is not a background utility with narrow local impact; it is a security gateway that frequently sits in front of high-value enterprise communications and mobile workflows. That placement amplifies the consequence of `CVE-2026-10520``. A root shell on the appliance can expose authentication material, control over traffic flows, and visibility into the very channels the product was meant to secure. In practical enterprise terms, that can translate into exposure of Exchange-connected mail traffic, abuse of trusted mobile application paths, and impersonation or replay opportunities against downstream services.

The vulnerability also arrives in a product family with an established history of high-interest security issues. Secondary reporting reviewed for this task notes that Ivanti Sentry was previously affected by `CVE-2023-38035`, an authentication-bypass zero-day, and Ivanti's broader ecosystem has faced sustained attacker attention across Connect Secure, EPMM, and adjacent products. That history matters because it increases the probability that threat actors and opportunistic scanners already monitor Ivanti exposure and can operationalize new Sentry flaws quickly once public technical cues appear.

The strongest current exploitation signal is CISA KEV inclusion. KEV status alone is enough to justify high-priority response because it indicates federal confidence that exploitation has occurred. Additional post-disclosure reporting that cites Shadowserver observations suggests attackers moved quickly once public PoC material became available, reportedly identifying a small population of still-vulnerable internet-facing appliances and finding at least some already backdoored. Because those claims are secondary rather than direct primary-source telemetry in the reviewed set, they should be framed with medium confidence, but they are directionally consistent with the risk profile of an unauthenticated `CVSS 10.0` gateway bug.

ATT&CK mapping	Relevance	Confidence
`T1190` Exploit Public-Facing Application	Best-fit initial access technique for unauthenticated exploitation of an internet-reachable Sentry web application path.	High
`T1059.004` Command and Scripting Interpreter: Unix Shell	Plausible execution technique because the flaw is an OS command injection leading to root-level command execution.	High
`T1550` Use Alternate Authentication Material	Plausible follow-on objective if attackers steal or replay session tokens or other trusted authentication material exposed by the gateway role.	Medium
`T1078` Valid Accounts	Plausible downstream effect if compromised sessions or credentials let the attacker impersonate legitimate mobile or mail users.	Medium

6. Detection and Hunting

The reviewed public record gives defenders a rare advantage for a fresh KEV item: a concrete web path associated with the vulnerable configuration handler. That means response teams should not limit activity to “patch and move on.” They should query reverse proxy, WAF, load balancer, firewall, and web access logs for requests touching `/mics/api/v2/sentry/mics-config/handleMessage`, inspect all `/mics` traffic for suspicious POST patterns or anomalous clients, and correlate any hits with appliance-side process creation, outbound network traffic, or evidence of persistence.

6.1 Detection Logic Summary

Signal	Telemetry source	Analytic goal
Requests to `/mics/api/v2/sentry/mics-config/handleMessage`	Reverse proxy logs, WAF logs, web access logs, packet captures	Identify direct interaction with the publicly discussed vulnerable endpoint
Internet-exposed hosts serving `/mics/login.jsp` or related `/mics` application content	External attack-surface inventory, ASM, Nuclei, internal scanning	Find reachable Sentry instances that require emergency validation
Sentry appliance-side command execution shortly after inbound `/mics` requests	Linux audit logs, EDR, Sysmon-for-Linux, shell history, process accounting	Detect likely successful command injection and post-exploitation activity
New outbound connections from the Sentry	Firewall logs, NetFlow, EDR network	Surface backdoor staging, operator access,

host to unfamiliar infrastructure	telemetry, DNS logs	or data exfiltration
Administrative account creation or anomalous configuration changes on Sentry	Application audit logs, config backups, admin-event logs	Catch follow-on abuse, especially where operators may chain with `CVE-2026-10523` or use the same access window for persistence

Analyst caveat: a request to the vulnerable path is not automatic proof of compromise. It is, however, a strong triage lead because that endpoint is not a casual user-facing business workflow path discussed in ordinary mobile-device operations.

6.2 Example Sigma Logic

<pre> title: Ivanti Sentry Request to Publicly Discussed Config Handler id: cve-2026-10520-ivanti-sentry-config-handler-request status: experimental description: Detects web requests to the Ivanti Sentry configuration handler path discussed in public CVE-2026-10520 research and PoC material. logsource: category: webserver product: linux detection: selection_uri: cs-uri-stem contains: '/mics/api/v2/sentry/mics-config/handleMessage' selection_method: cs-method: - POST - GET condition: selection_uri and selection_method falsepositives: - authorized internal validation using trusted detection tooling - benign product-specific administrative traffic if the path is legitimately used in the environment level: high </pre>

6.3 Example Hunt Queries

Microsoft Sentinel / Defender style hunt for suspicious requests in generic web-application logs:

<pre> let lookback = 30d; CommonSecurityLog where TimeGenerated > ago(lookback) where RequestURL has "/mics/api/v2/sentry/mics-config/handleMessage" or RequestURL has "/mics/login.jsp" summarize FirstSeen=min(TimeGenerated), LastSeen=max(TimeGenerated), RequestCount=count(), SrcIPs=make_set(SourceIP, 50), UserAgents=make_set(RequestClientApplication, 50) by DeviceName, RequestURL, DestinationIP, RequestMethod order by LastSeen desc </pre>

Process-and-network follow-up hunt for a Linux-monitored Sentry host after suspicious inbound web activity:

<pre> let suspiciousRequests = CommonSecurityLog where TimeGenerated > ago(30d) where RequestURL has "/mics/api/v2/sentry/mics-config/handleMessage" project DeviceName, DestinationIP, RequestTime=TimeGenerated, SourceIP; let suspiciousProcesses = DeviceProcessEvents where Timestamp > ago(30d) where InitiatingProcessFileName in~ ("java", "java.bin") or FileName in~ ("sh", "bash", "curl", "wget", "python", "perl") project DeviceName, ProcessTime=Timestamp, FileName, ProcessCommandLine, InitiatingProcessFileName, InitiatingProcessCommandLine; suspiciousRequests join kind=inner suspiciousProcesses on DeviceName where ProcessTime between (RequestTime .. RequestTime + 15m) project RequestTime, ProcessTime, DeviceName, DestinationIP, SourceIP, FileName, ProcessCommandLine, InitiatingProcessFileName, InitiatingProcessCommandLine order by ProcessTime desc </pre>

Practical validation command for asset inventory and bundle review:


```
rg -n '/mics/api/v2/sentry/mics-config/handleMessage|/mics/login.jsp|Ivanti Sentry|MobileIron
Sentry' /var/log /srv /opt 2>/dev/null
```

6.4 Hunting Guidance

Hunt question	Why it matters
Which Sentry appliances were reachable from the internet at or after disclosure?	Reachability is the most important exposure multiplier in the reviewed public record.
Did any host receive requests to <code>/mics/api/v2/sentry/mics-config/handleMessage`</code> ?	This is the strongest immediate pivot from the public research set.
Did suspicious requests correlate with shell execution, outbound callbacks, or config changes on the appliance?	That sequence materially strengthens the case for successful exploitation.
Were credentials, session tokens, or downstream service connections exposed through the gateway after suspicious activity?	Business impact likely extends beyond the appliance itself.
Are there unpatched hosts “protected” only by partial access controls such as restricted HTTPS or upstream filtering?	These systems remain high priority because exposure assumptions are brittle and can fail during misconfiguration or lateral access scenarios.

7. Recommendations

Priority	Owner	Action
Critical	Infrastructure / Messaging / MDM Owners	Upgrade Ivanti Sentry to <code>`R10.5.2`</code> , <code>`R10.6.2`</code> , or <code>`R10.7.1`</code> (or later) immediately and verify the running build rather than assuming maintenance windows succeeded.
Critical	Network Security	Identify every internet-reachable <code>`/mics`</code> interface and restrict direct external access wherever operationally feasible.
Critical	Incident Response	Treat unpatched internet-exposed Sentry appliances as potentially compromised, review logs from 2026-06-09 forward, and preserve forensic evidence before remediation if suspicious activity is present.
High	IAM / Messaging / Application Owners	Invalidate or review exposed sessions, tokens, certificates, and dependent service credentials that may have traversed or been stored on the compromised gateway.
High	Detection Engineering	Add high-priority detections for <code>`/mics/api/v2/sentry/mics-config/handleMessage`</code> requests and correlate them with appliance-side shell or network activity.
High	Vulnerability Management	Flag Ivanti Sentry as an emergency-patch asset class and verify that instances thought to be “not internet-facing” are actually unreachable from untrusted networks.
Medium	Security Architecture	Review whether Sentry should remain

		directly reachable from the internet or whether a more constrained brokered design is possible for future deployments.
Medium	Threat Intelligence	Monitor Ivanti, CISA KEV, Shadowserver-related reporting, and watchTowr updates for changes in attacker tradecraft, exploit reliability, or additional post-exploitation guidance.

Additional analyst guidance:

- Do not stop at patch verification. If the appliance was reachable and unpatched after public technical details emerged, compromise assessment should be part of the response scope.
- Treat paired vulnerability context seriously. Even though this report is focused on `CVE-2026-10520`, defenders should review the same maintenance event for `CVE-2026-10523` because both issues affect the same product line and administrative trust boundary.
- Preserve pragmatic evidence. Reverse-proxy logs, full request URIs, appliance process history, config snapshots, and outbound connection metadata are likely to be more valuable than waiting for perfect malware IOCs.

8. References

- 1. Ivanti Security Advisory - `Security Advisory Ivanti Sentry (CVE-2026-10520, CVE-2026-10523)`: https://hub.ivanti.com/s/article/Security-Advisory-Ivanti-Sentry-CVE-2026-10520-CVE-2026-10523?language=en_US
- 2. CISA Known Exploited Vulnerabilities Catalog entry / feed reference for `CVE-2026-10520`: https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-10520
- 3. NVD record for `CVE-2026-10520`: <https://nvd.nist.gov/vuln/detail/CVE-2026-10520>
- 4. watchTowr Labs technical analysis - `More Evidence That Words Don't Mean What We Thought They Meant (Ivanti Sentry Pre-Auth OS Command Injection CVE-2026-10520)`: <https://labs.watchtowr.com/more-evidence-that-words-dont-mean-what-we-thought-they-meant-ivanti-sentry-pre-auth-os-command-injection-cve-2026-10520/>
- 5. watchTowr detection artifact generator repository: <https://github.com/watchtowrlabs/watchTowr-vs-Ivanti-Sentry-RCE-CVE-2026-10520-CVE-2026-10523>
- 6. Help Net Security - `Critical Ivanti Sentry flaw allows root-level remote code execution (CVE-2026-10520)`: <https://www.helpnetsecurity.com/2026/06/10/ivanti-sentry-cve-2026-10520-cve-2026-10523/>
- 7. The Hacker News - `Ivanti, Fortinet, and SAP Release Patches for Multiple Critical Flaws`: <https://thehackernews.com/2026/06/ivanti-fortinet-and-sap-release-patches.html>
- 8. Security Affairs - `CVE-2026-10520 Exploited: Ivanti Sentry Gateways Compromised Shortly After Patch Release`: <https://securityaffairs.com/193530/uncategorized/cve-2026-10520-exploited-ivanti-sentry-gateways-compromised-shortly-after-patch-release.html>